

Vulnerability Assessment & Penetration Testing Report

Client: Internal Lab Environment

Date: July 2026

Prepared By: Anjali Saini

1. Executive Summary

A comprehensive vulnerability assessment and penetration test was conducted on a Windows 11 target system in an isolated lab environment. The assessment aimed to identify security weaknesses that could be exploited by an attacker.

Key Findings:

- Windows Defender (with real-time protection enabled) was bypassed using advanced evasion techniques
- Privilege escalation from standard user to SYSTEM was achieved
- Persistence mechanisms were successfully established

2. Scope of Assessment

Item	Detail
Target	Windows 11 (VM) – fully updated, Defender enabled
Attacker	Kali Linux
Tools Used	Metasploit Framework, msfvenom, HollowGhost, PowerShell
Objective	Simulate real-world attack chain to identify security gaps

3. Methodology

3.1 Attack Chain Overview

The following steps were performed in sequence:

Step	Activity
1	Generated raw shellcode using msfvenom
2	Used AES-256 encryption and process hollowing to create undetectable payload
3	Delivered payload via USB drive with automated installer
4	Established Meterpreter session
5	Escalated privileges to SYSTEM level
6	Maintained persistence after system reboot

4. Detailed Findings

Finding 1: Windows Defender Evasion

Observation:

An executable payload was generated using AES-256 encryption and process hollowing technique. The resulting file (payload.exe) was not detected by Windows Defender during testing.

Impact:

An attacker can execute malicious code without triggering security alerts, potentially leading to full system compromise.

Affected Systems:

Windows 11 with default Defender settings

Recommendation:

- Monitor for suspicious process creation events (Event ID 4688) and PowerShell execution logs (Event ID 4104)
- Consider application control solutions (AppLocker or Windows Defender Application Control)

Finding 2: Privilege Escalation

Observation:

A standard user account was successfully escalated to SYSTEM-level privileges using UAC bypass techniques.

Impact:

An attacker with standard user access can gain complete administrative control over the system.

Affected Systems:

Windows 11 with default UAC settings

Recommendation:

- Enforce UAC for all users with maximum protection level
 - Limit local administrator privileges
 - Monitor for suspicious process creation events (Event ID 4688)
-

Finding 3: Persistence Mechanism

Observation:

The payload was configured to execute automatically on system startup by placing it in the Windows Startup folder (C:\Users\USER_1\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup).

Impact:

Attacker maintains access even after system reboots and user logouts.

Affected Systems:

All Windows systems with default Startup folder permissions

Recommendation:

- Monitor Startup folder for unauthorized files
 - Use Group Policy to restrict Startup folder access
 - Implement Endpoint Detection and Response (EDR) with file creation monitoring.
-

Finding 4: Process Migration

Observation:

The Meterpreter payload was migrated to a legitimate Windows process (svchost.exe), hiding the malicious activity from system monitoring tools.

Impact:

Attackers can evade process-based detection and appear as normal system activity.

Affected Systems:

All Windows systems

Recommendation:

- Monitor for unusual process migration (Event ID 4688 with suspicious parent-child relationships)
- Use EDR solutions with behavior monitoring capabilities.

5. Risk Assessment Summary

Finding	Severity	Impact	Recommendation
Windows Defender Bypass	Critical	Full system compromise	Deploy EDR solutions, enable cloud protection
Privilege Escalation	Critical	Administrative access	Enforce UAC, limit local admin privileges
Persistence Mechanism	High	Long-term unauthorized access	Monitor Startup folder, restrict permissions
Process Migration	Medium	Detection evasion	Implement behavior monitoring

6. Conclusion

This assessment demonstrated that a Windows 11 system with default security configurations can be fully compromised through a combination of evasion techniques and privilege escalation.

Key Lessons:

- Defender alone is insufficient to stop advanced attacks, even with all features enabled.
 - User accounts require stricter privilege controls
 - Detection requires monitoring beyond static signatures
-

7. Recommendations

1. **Endpoint Security:** Deploy EDR solution with behavioral detection
 2. **Access Control:** Implement least privilege access and enforce UAC
 3. **Monitoring:** Monitor Startup folder, process creations (Event ID 4688), and privilege escalations
 4. **Patching:** Keep Windows and Defender updated with latest definitions
 5. **User Awareness:** Train users to recognize social engineering attacks
-

8. Appendix

Tools Used:

- Kali Linux (attacker)
- Metasploit Framework
- msfvenom
- HollowGhost
- Windows PowerShell

Environment:

- Windows 11 (target)
 - VMware Workstation
-

Prepared By: Anjali Saini

Date: July 2026